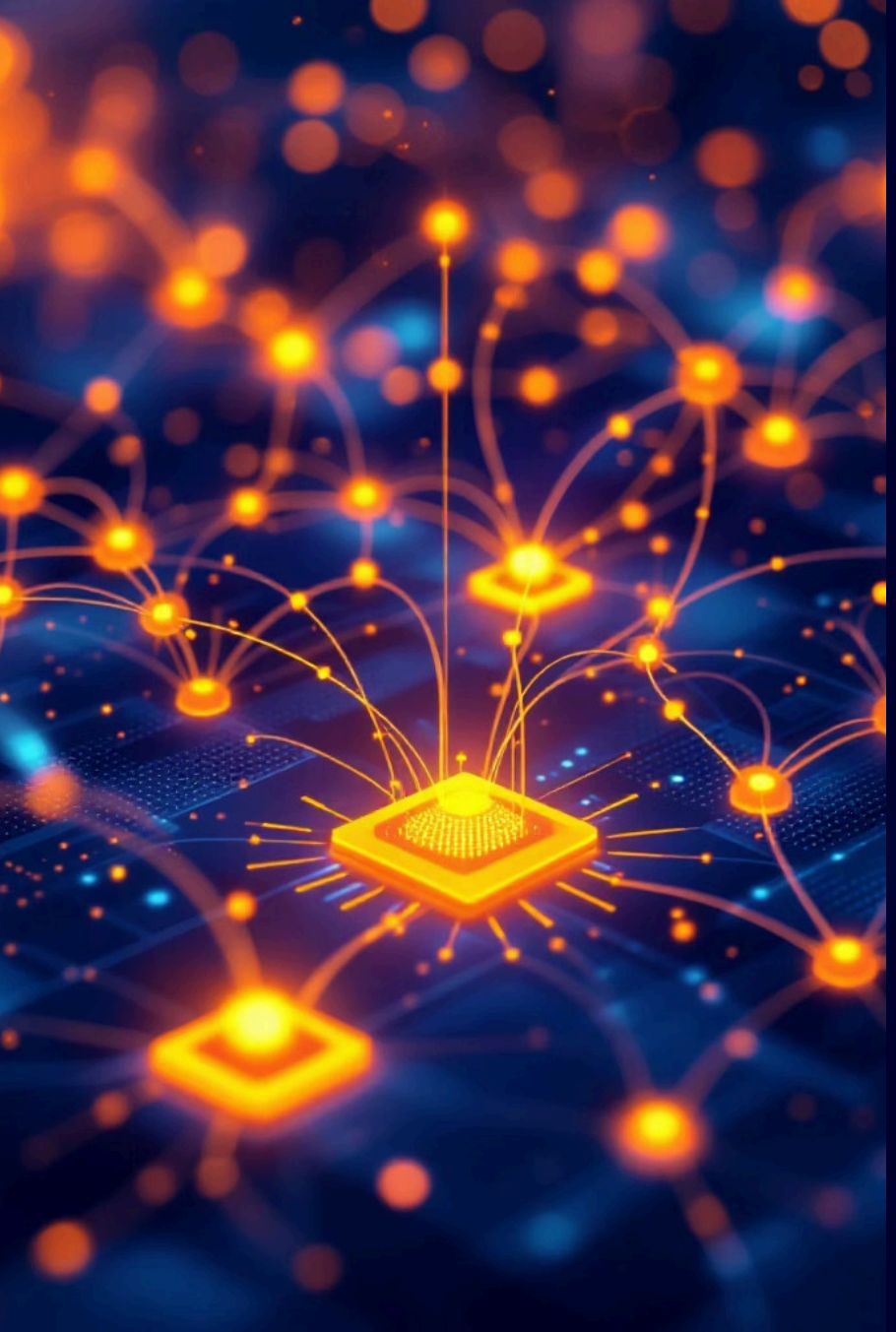
Proyecto Final

Servidor WEB Comprometido

Realizado por:

Anied Arpisa

Marzo 2026



Objetivo y Alcance

Objetivo

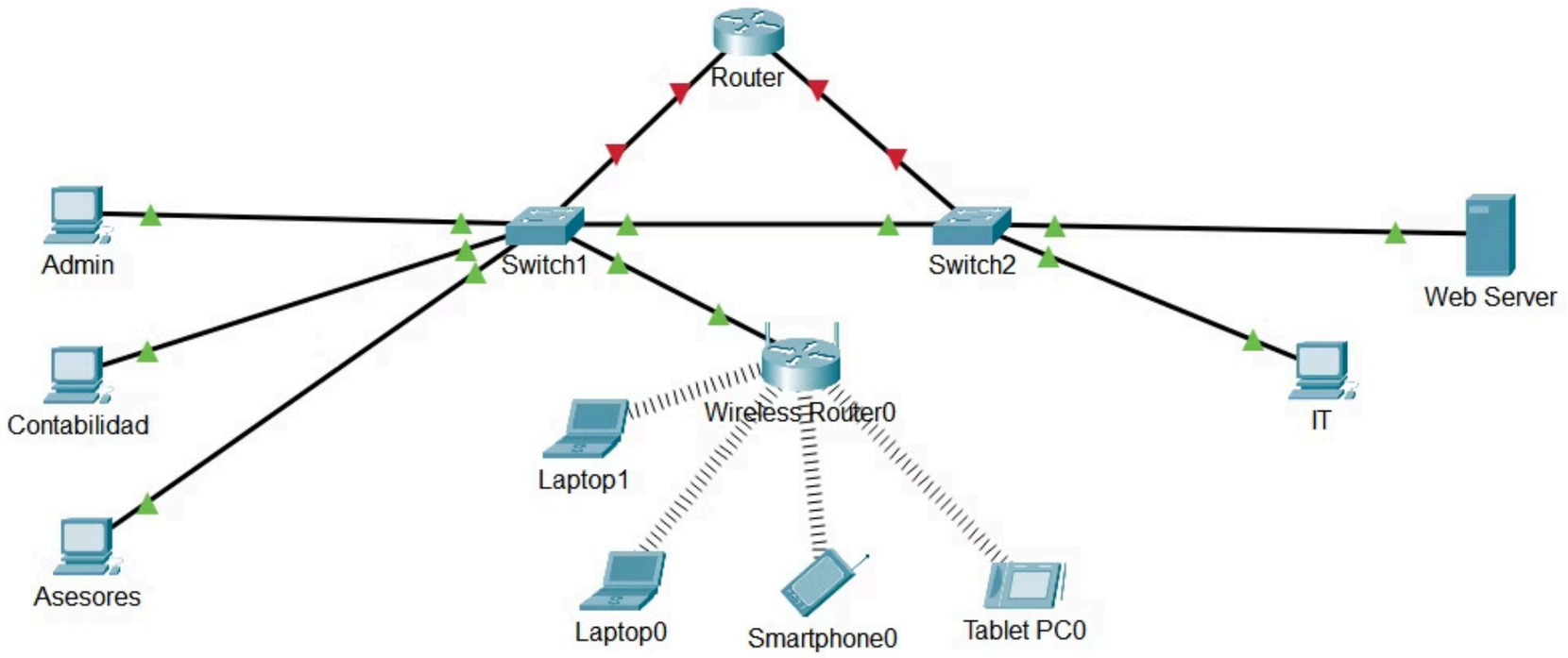
Realizar una auditoría de seguridad integral del servidor web de 4Geeks Academy mediante pruebas de penetración exhaustivas para identificar vulnerabilidades y proteger los activos de información.

Alcance

- **Servidor evaluado:** 192.168.0.137
- **Componentes analizados:**

  - Sitio web
  - Acceso remoto
  - Transferencia de archivos
  - Base de datos
  - Sistema de gestión de contenidos

Diagrama de Red



Vulnerabilidades Críticas Detectadas

Puertos abiertos

Puertas abiertas en el servidor que permiten que cualquiera se conecte sin restricción.

Credenciales Débiles

Contraseñas guardadas de forma insegura y fáciles de descifrar.

Lista de Directorios

Carpetas del servidor que se pueden ver y descargar sin permiso.

Servicios sin Cifrado

Información que viaja sin protección, como si fuera en una postal abierta.

Permisos Inseguros

Archivos importantes que cualquiera puede leer, modificar o eliminar.

Rootkit detectado

Software malicioso que toma control del servidor sin ser detectado.

Falta de Firewall

No hay un guardián que controle quién entra y sale del servidor.

Nivel de Riesgo por amenaza

Secuestro de sesión / Escalada de privilegios

CRÍTICO

Acceso no autorizado al Sistema Operativo

ALTA

Interceptación de credenciales (Sniffing)

ALTA

Fuerza bruta contra contraseñas

CRÍTICO

Exfiltración de información sensible

Media

Denegación de Servicio (DoS)

ALTA

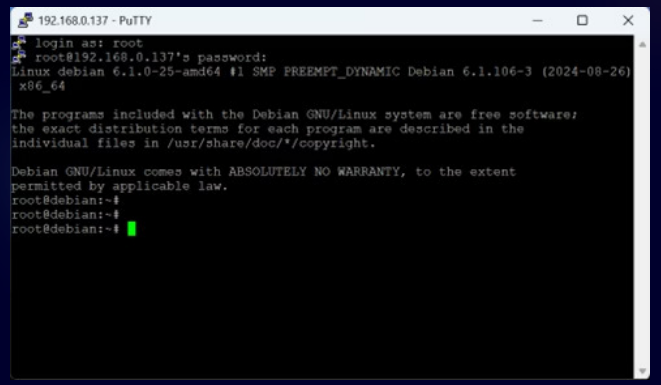
Explotación de servicios

ALTA

Toma de control por fuerza bruta / Diccionario

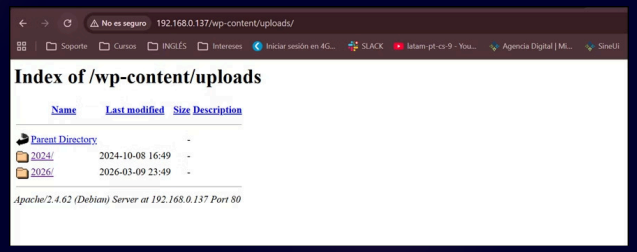
CRÍTICO

Prueba de Vulnerabilidades



Acceso no permitido

Conexión remota al servidor web con la cuenta superusuario. Con esta cuenta se puede acceder, robar o modificar cualquier información en el servidor.



Listado de Directorios

Muestra una lista de todos los archivos y carpetas, y permite descargar todo el contenido multimedia y documentos de la web sin restricción.

Descifrado de contraseña

Se obtuvo la contraseña usada por los usuarios de la base de Datos.

Consecuencias

Puertos abiertos

Pérdida de control total del servidor y acceso no autorizado a todos los sistemas.

Credenciales Débiles

Robo de identidades de usuarios y acceso a cuentas administrativas críticas.

Lista de Directorios

Exposición de documentos confidenciales, datos de clientes y secretos comerciales.

Servicios sin Cifrado

Interceptación de información sensible, números de tarjeta y datos personales.

Permisos Inseguros

Modificación o eliminación de datos críticos, sabotaje del sitio web.

Rootkit detectado

Pérdida permanente de confianza en la integridad del servidor y datos comprometidos.

Falta de Firewall

Ataques continuos, caída del servicio y pérdida de disponibilidad del sitio web.

Impacto Empresarial

1. Pérdida de Clientes

Clientes que descubren el compromiso del servidor abandonan la plataforma y buscan competidores más seguros.

2. Daño a la Reputación

Mala publicidad en redes sociales, prensa negativa y pérdida de confianza en la marca de 4Geeks Academy.

3. Pérdida de Ingresos

Caída del sitio web, clientes sin acceso, cancelación de suscripciones y pérdida de ventas diarias.

4. Multas y Sanciones Legales

Incumplimiento de regulaciones de protección de datos y posibles demandas de clientes afectados.

5. Costos de Recuperación

Gastos en expertos de seguridad, reconstrucción del servidor, auditorías forenses y compensación a clientes.

6. Pérdida de Ventaja Competitiva

Robo de secretos comerciales, información de clientes y planes estratégicos por competidores.

Propuesta de Prevención

01

Políticas de Contraseñas

Establecer contraseñas complejas y evitar reutilización de claves entre usuarios críticos.

02

Gestión de Parches

Calendario de mantenimiento para mantener Apache, OpenSSH y vsftpd actualizados.

03

Cifrado por Defecto

Migrar servicios a versiones cifradas: HTTP a HTTPS, FTP a SFTP o FTPS.

04

Configuración de Firewall

Implementar reglas estrictas en IPTABLES permitiendo solo tráfico necesario.

05

Hardening de SSH

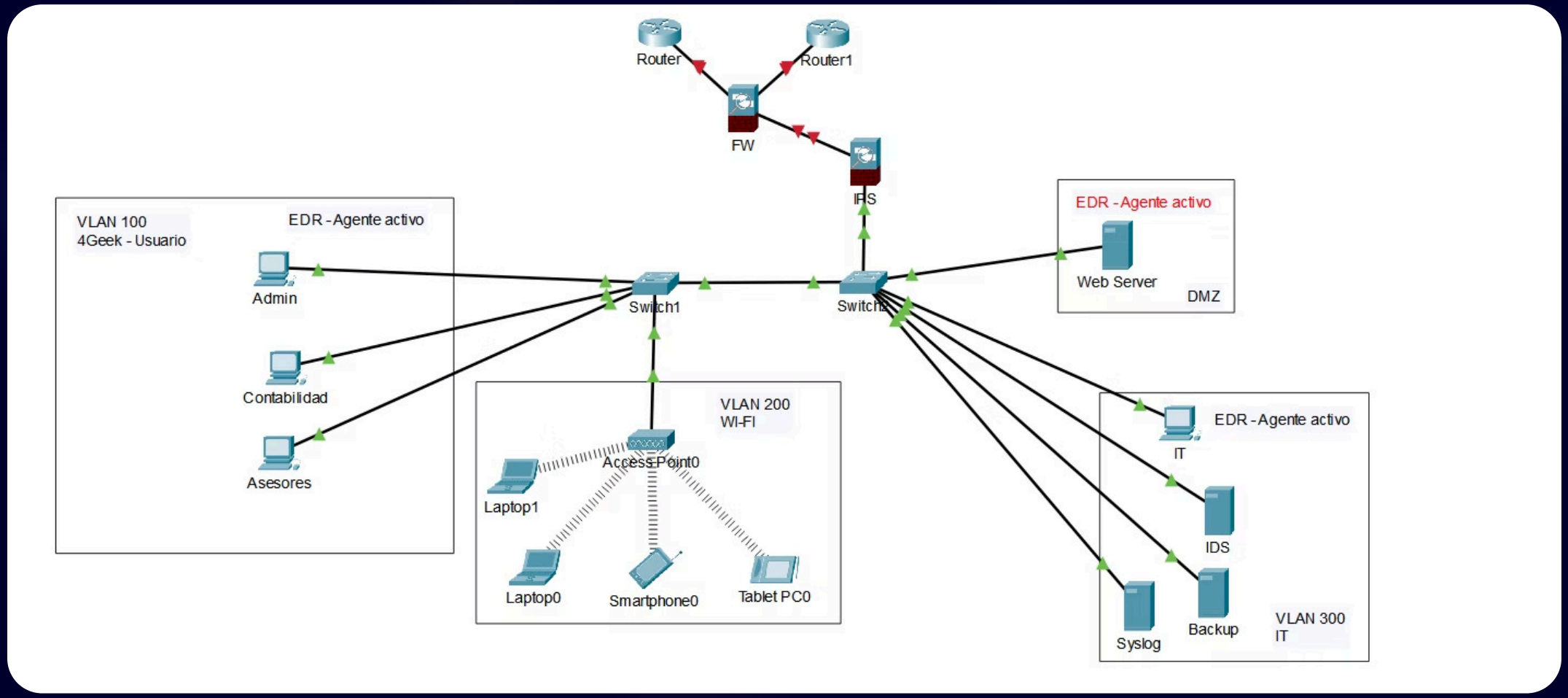
Prohibir acceso directo al usuario root y configurar autenticación más segura.

06

Implementación de IDS

Instalar herramientas para monitorear cambios y generar alertas automáticas.

Diagrama de Red Sugerido



Recomendaciones

Implementación de Medidas

Aplicar propuestas de prevención y mitigación.

Re-escaneo de Seguridad

Realizar nueva auditoría tras implementación para verificar correcciones

Monitoreo Continuo

Establecer sistema de monitoreo permanente de vulnerabilidades